Contents

ASVS Conformance Target **1**
Levels, briefly . . . 1
Scope . . . 1
Why not Level 2 everywhere . . . 3
Where each chapter is implemented . . . 3
Verification . . . 4
Status . . . 4
Related . . . 4

ASVS Conformance Target

Which parts of the OWASP Application Security Verification Standard this project commits to, at which level, and why. Decision: [[ADR-0009-code-quality-gates]].

Source: ASVS **5.0.0**, vendored verbatim in `upstream/asvs-5.0.0/` — see [[owasp-provenance]]. Requirements are referenced by id. Their text is in the upstream CSV and JSON, not copied here.

Levels, briefly

Level	Meaning
L1	the baseline every application should meet
L2	applications handling meaningful personal data or transactions
L3	high-assurance systems

Scope

345 requirements across 17 chapters. This project commits to **142** of them.

Ch	Chapter	L1	L2	L3	Committed	Rationale
V1	Encoding and Sanitization	8	19	3	**L1**	user-supplied text reaches the database and other users' screens
V2	Validation and Business Logic	4	7	2	**L1**	vote and licence rules are business logic with abuse potential
V3	Web Frontend Security	8	11	12	*conditional*	no web frontend today; becomes L1 if the responsive-web bonus is built

Ch	Chapter	L1	L2	L3	Committed	Rationale
V4	API and Web Service	2	8	6	**L1**	the API is the entire attack surface
V5	File Handling	4	5	4	**L1**	no uploads are designed, but profile imagery would land here
V6	Authentication	13	22	12	**L2**	subject V.1 and V.6 grade this directly
V7	Session Management	6	12	1	**L2**	subject V.6 names session hijacking explicitly
V8	Authorization	4	3	6	**L2**	subject V.6: a user reaches own data only; plus visibility and licence gates
V9	Self-contained Tokens	4	3	0	**L2**	we issue JWTs ourselves
V10	OAuth and OIDC	5	24	7	**L2**	Google and Facebook sign-in — [[ADR-0008-oidc-social-login]]
V11	Cryptography	3	11	10	**L1**	password hashing, token signing — [[ADR-0007-password-hashing-bcrypt]]
V12	Secure Communication	3	6	3	**L1**	HTTPS and WebSocket over TLS
V13	Configuration	1	12	8	**L1**	`.env` discipline, subject V.8

Ch	Chapter	L1	L2	L3	Committed	Rationale
V14	Data Protection	2	7	4	**L1**	three profile visibility tiers hold personal data
V15	Secure Coding and Architecture	3	10	8	**L1**	dependency and coding hygiene
V16	Security Logging and Error Handling	0	16	1	**L2**	the mandatory audit log is subject V.6; there are no L1 rows in this chapter
V17	WebRTC	0	7	5	**out of scope**	no peer-to-peer media; playback is client-side YouTube

Committed = 62 L1 requirements (all chapters except V3 and V17) + 80 L2 requirements (V6, V7, V8, V9, V10, V16).

Why not Level 2 everywhere

A conformance claim you cannot demonstrate is worth less than a narrower one you can. L2 is committed exactly where subject V.6 is graded and where this system's real risk sits: identity, sessions, tokens, authorization, federated login, and the audit trail. Claiming L2 across all 17 chapters would mean claiming 183 verified requirements that no one on this team has verified.

State this reasoning at defence. "We chose our scope and can show it" beats "we ticked everything".

Where each chapter is implemented

Chapter	Primary implementation	Rules
V1, V2	FluentValidation in the pipeline; EF Core parameterised queries	[[application-security]]
V4	REST contract, Problem Details, pagination caps	[[rest-api-design]]
V6, V7, V9	BCrypt, JWT + rotating refresh tokens, revocation	[[authentication-authorization]]
V8	the two authorisation gates, evaluated in a pipeline behaviour	[[sdd]] §13.2
V10	authorization code + PKCE, server-side ID token validation	[[social-oauth]]
V11	BCrypt work factor, JWT signing key from `.env`	[[ADR-0007-password-hashing-bcrypt]]
V12	HTTPS, HSTS, TLS for the SignalR transport	[[application-security]]

Chapter	Primary implementation	Rules
V13	`.env`, `.env.example`, no secret in source or image	[[secrets-management]]
V14	per-field profile filtering, soft delete, data minimisation	[[sdd]] §13.2
V15	analyzers, size limits, vulnerable-dependency scan	[[dotnet-csharp]], [[ci-cd-containerization]]
V16	the audit table, structured logging, the never-logged list	[[logging-observability]]

Verification

A requirement counts as met when there is **evidence**, not intent:

Evidence	Example
a test	the negative authorisation test for V8
an analyzer rule	the vulnerable-package scan for V15
a configuration artifact	`.env.example` and the ignore rule for V13
a design element plus a code path	the audit behaviour for V16

Unmet requirements are not deleted from this table. They go to [[threat-register]] with their residual risk.

Status

No code exists yet, so **no requirement is verified**. This document states the commitment; the evidence column gets filled slice by slice, per [[delivery-plan]] Phase 4.

Related

[[owasp-index]] · [[owasp-top10-checklist]] · [[threat-register]] · [[ADR-0009-code-quality-gates]]